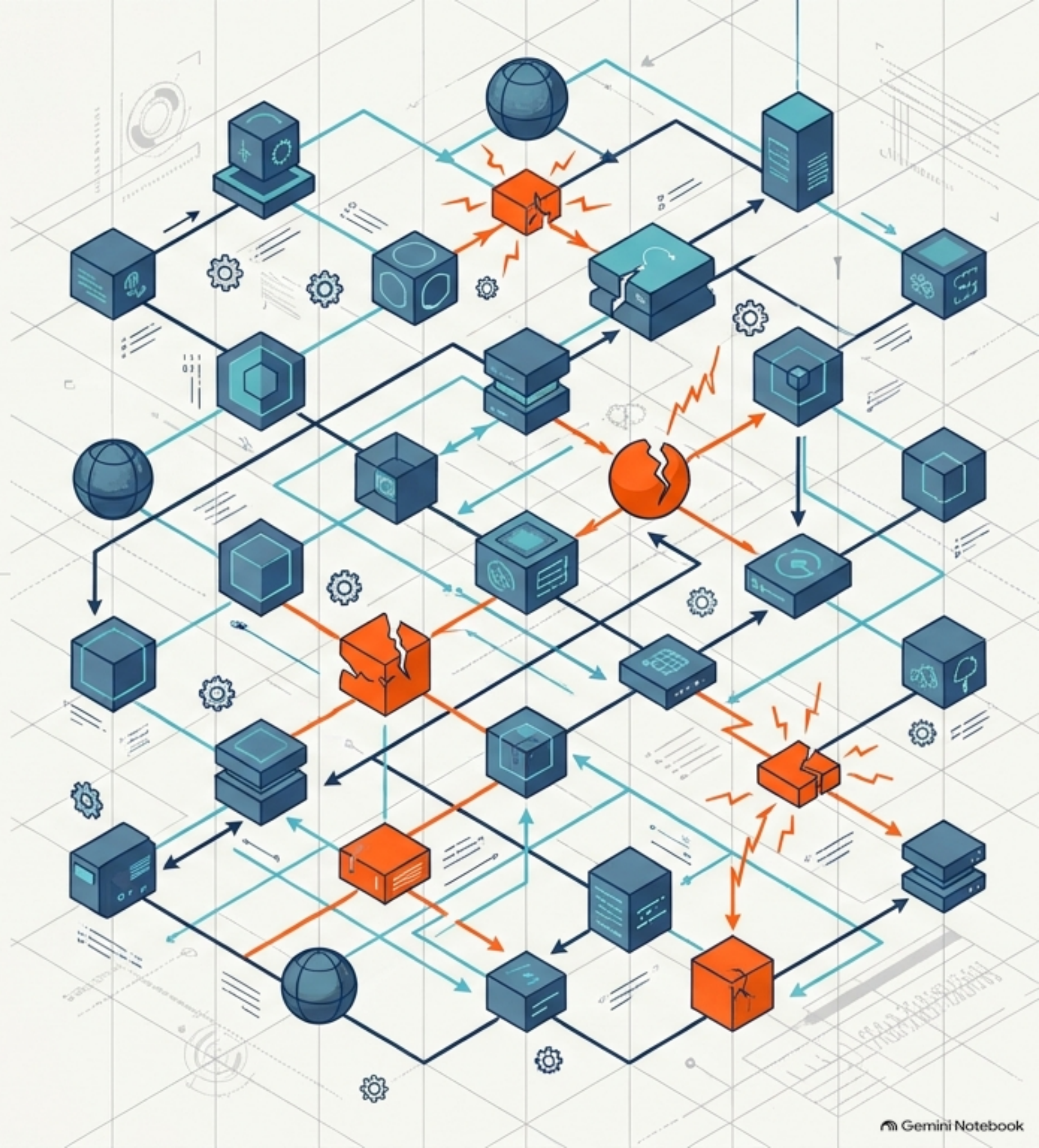
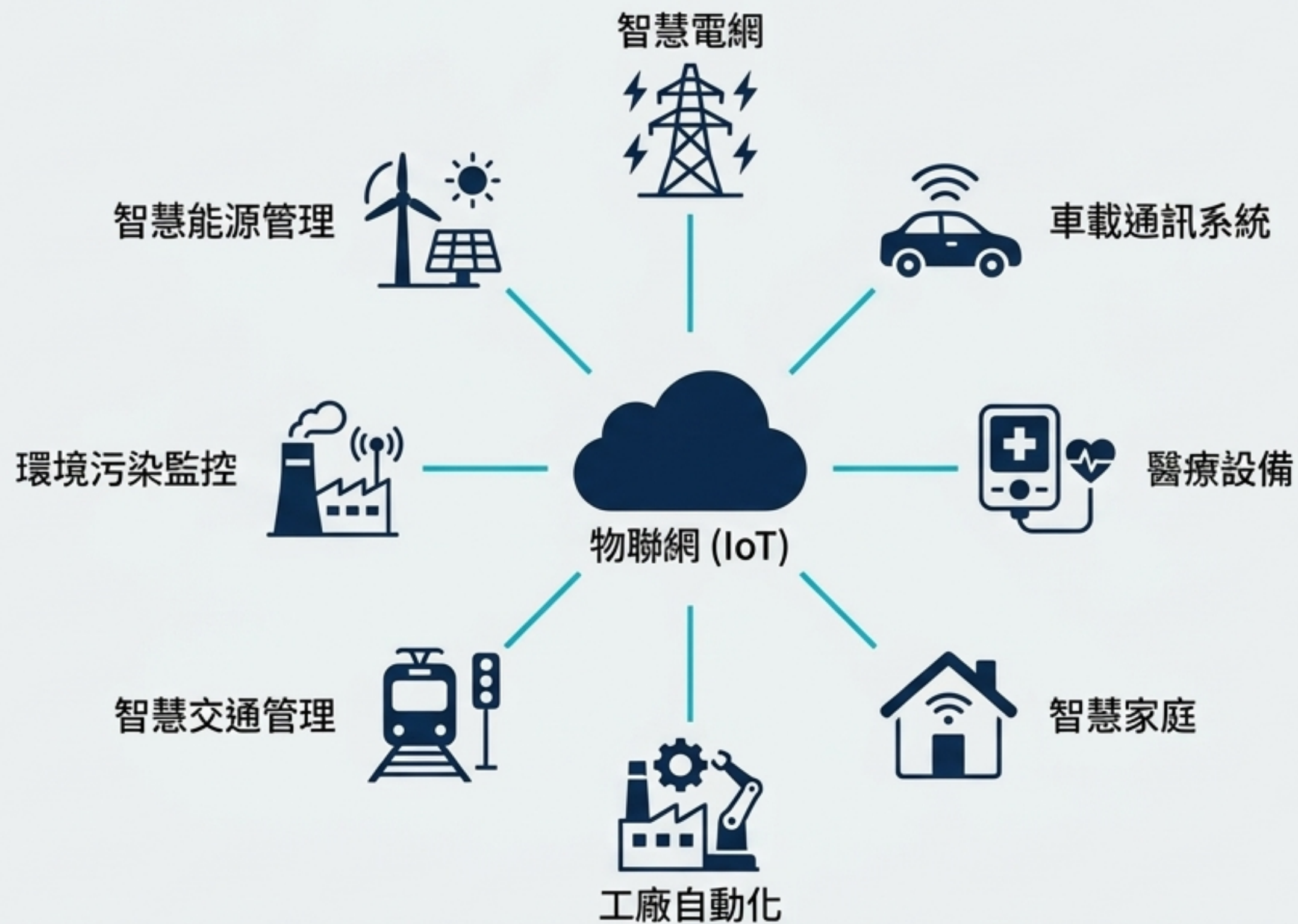


物聯網安全防禦指南

從三層架構剖析
OWASP 十大弱點與威脅防禦

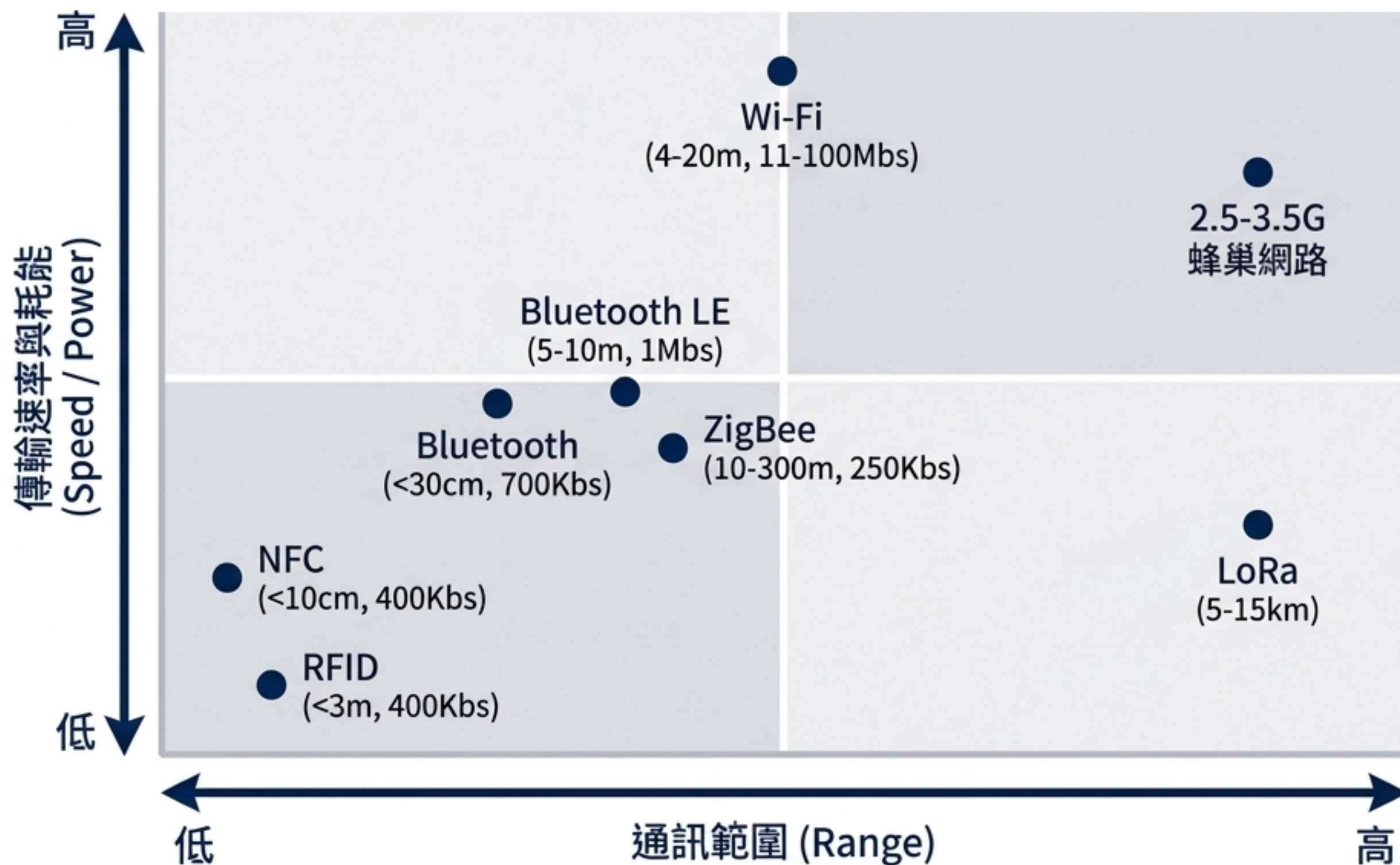


萬物聯網 (IoE)：無所不在的生態體系



將微型感測晶片嵌入物件，賦予萬物溝通與智慧化能力，重塑現代生活與工業命脈。

IoT 通訊技術選型矩陣



LoRa (LPWAN) 技術特寫

具備長距離（5-15公里）、高穿透、抗干擾特性，專為物聯網量身打造的低功耗廣域網路解決方案。

物聯網立體架構解析



高層：應用層 (Application Layer)

平台 (IoT Platform)：處理及分享龐大複雜的資訊。

服務 (Service Layer)：技術融合，發展醫療照護、智慧電網等應用子系統。

中層：網路層 (Network Layer)

閘道器 (Gateway)：解決終端處理與連網能力不足，轉換短距通訊為廣域網路。

底層：感測層 (Sensing Layer)

聯網裝置 (Devices/Things)：識別、感測與控制終端狀態（如溫濕度感測器、GPS、RFID）。

核心威脅與崩潰邊緣

監聽攻擊 (Sniffing)：竊取明文資訊。

阻斷服務 (DoS)：封鎖網路或癱瘓設備效能。

金鑰竊取 (Key Theft)：破解加密防線。

密碼攻擊 (Password Attack)：猜測或竊取密碼入侵。

中間人攻擊 (MitM)：攔截並竊取傳輸資料。

真實案例解析：Mirai 殭屍網路

手法：鎖定執行 Linux 系統的物聯網設備，利用基於密碼的攻擊，猜測原廠預設密碼 (如 0000、1111)。

後果：遠端操控淪為殭屍 (Bot)，組成龐大殭屍網路發動毀滅性網路攻擊。



OWASP IoT 十大弱點熱區圖

	聯網裝置	閘道器	物聯網平台	服務層
I1: 不安全網頁介面				
I2: 不充足驗證授權				
I3: 不安全網路服務				
I4: 缺乏傳輸加密				
I5: 隱私議題				
I6: 不安全雲端介面				
I7: 不安全行動介面				
I8: 安全設定不足				
I9: 不安全軟體				
I10: 缺乏實體安全				

架構診斷：越靠近終端邊緣，實體與網路服務越脆弱；越靠近雲端，介面與隱私威脅越集中。

防線潰堤：介面與網路服務漏洞

物聯網平台 (IoT Platform)

服務層 (Service Layer)

聯網裝置 (Connected Devices)

閘道器 (Gateway)

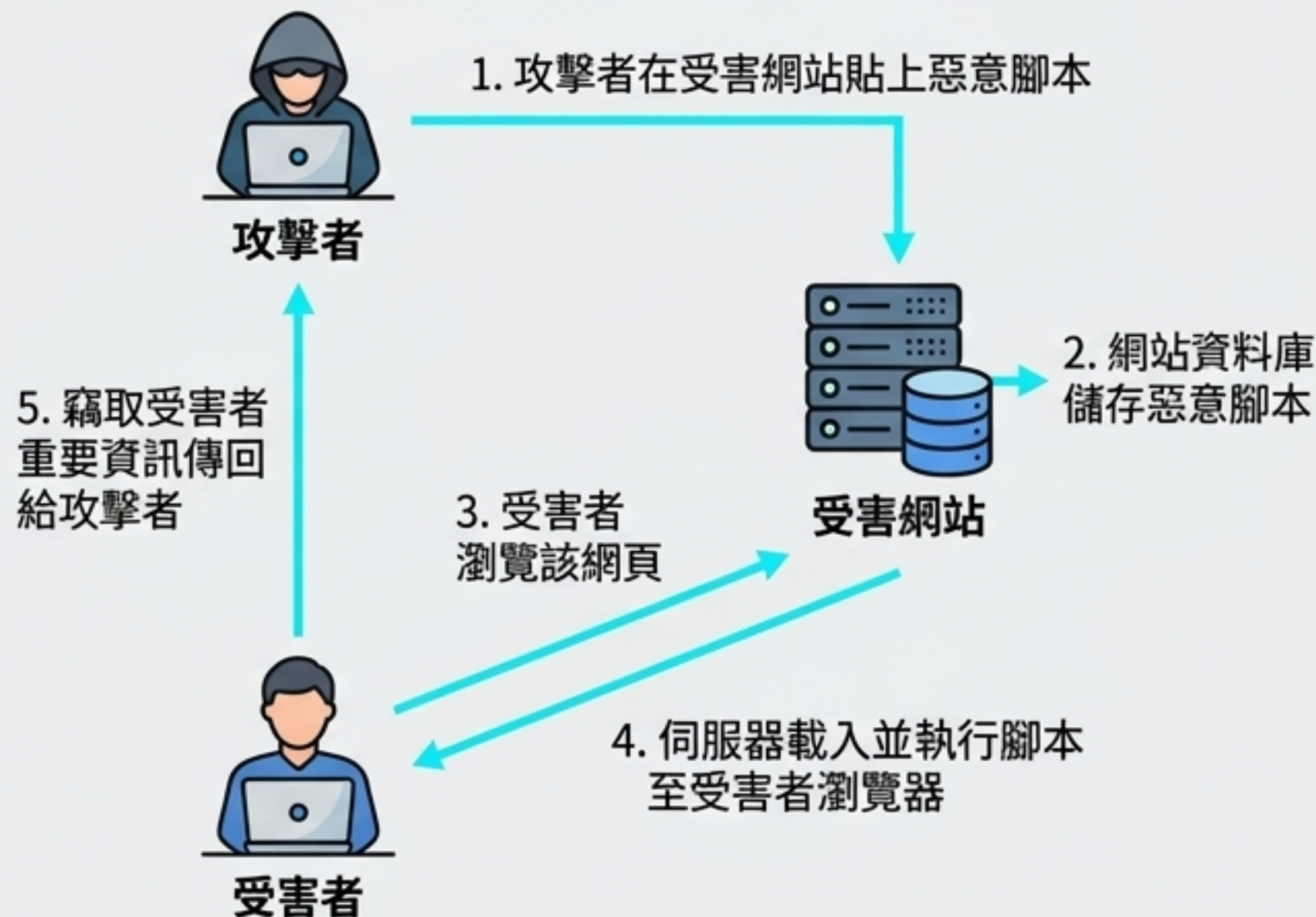
I1 / I6 / I7 (網頁/雲端/行動介面)

未經嚴謹驗證，易遭受 XSS、SQL Injection、CSRF 攻擊。行動裝置需強制帳戶鎖定與強密碼。

I3 (不安全的網路服務)

鎖定 Telnet 服務埠 (Port 23 / 2323)，利用預設密碼入侵嵌入式裝置 (如網路攝影機)。

跨站腳本攻擊 (XSS) 流程



敞開的大門：身分驗證與設定盲區 (I2, I8)

物聯網平台 (IoT Platform)

服務層 (Service Layer)

聯網裝置 (Connected Devices)

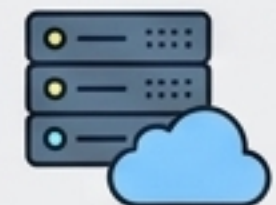
閘道器 (Gateway)

弱密碼 (高風險)	強密碼 (高防禦)
• 連續數字: 12345678	• 英數混雜: t3MlfreryeT410
• 重複數字: 111111	• 長度與特殊符號: Cert_100£toEus!
• 相鄰字母: abcdefg	
• 鍵盤相鄰: qwer	

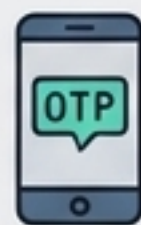
雙因子認證 (2FA/OTP) 防護機制



1. 登入請求 (輸入帳號與密碼)



2. 系統推播驗證要求至已綁定裝置



3. 手機接收並開啟一次性密碼 (OTP)



4. 輸入 OTP 完成雙重驗證

資料裸奔：缺乏加密與隱私洩漏 (14, 15)

物聯網平台 (IoT Platform)

服務層 (Service Layer)

聯網裝置 (Connected Devices)

閘道器 (Gateway)

70%



物聯網路傳輸未經加密

80%



裝置或雲端洩漏用戶個資 (姓名、信用卡等)

90%



裝置至少洩漏一項隱私資料



明文傳輸 (高風險)：資料可輕易被中間人攔截與竊取



SSL/TLS 加密通道 (安全)：資料經加密保護，阻絕中間人攻擊

防護對策：確保設備與網際網路間採用 SSL/TLS 加密通道；落實隱私最小化，僅收集必要個人資訊。

供應鏈毒藥：軟韌體竄改危機 (I9)

核心風險：透過不安全的網路下載更新，易遭中間人替換並植入惡意軟體。

物聯網平台 (IoT Platform)

服務層 (Service Layer)

聯網裝置 (Connected Devices)

閘道器 (Gateway)

防護生產線：程式碼簽章流程 (Code Signing)



最後防線：硬體的實體安全 (I10)

物聯網平台 (IoT Platform)

服務層 (Service Layer)

聯網裝置 (Connected Devices)

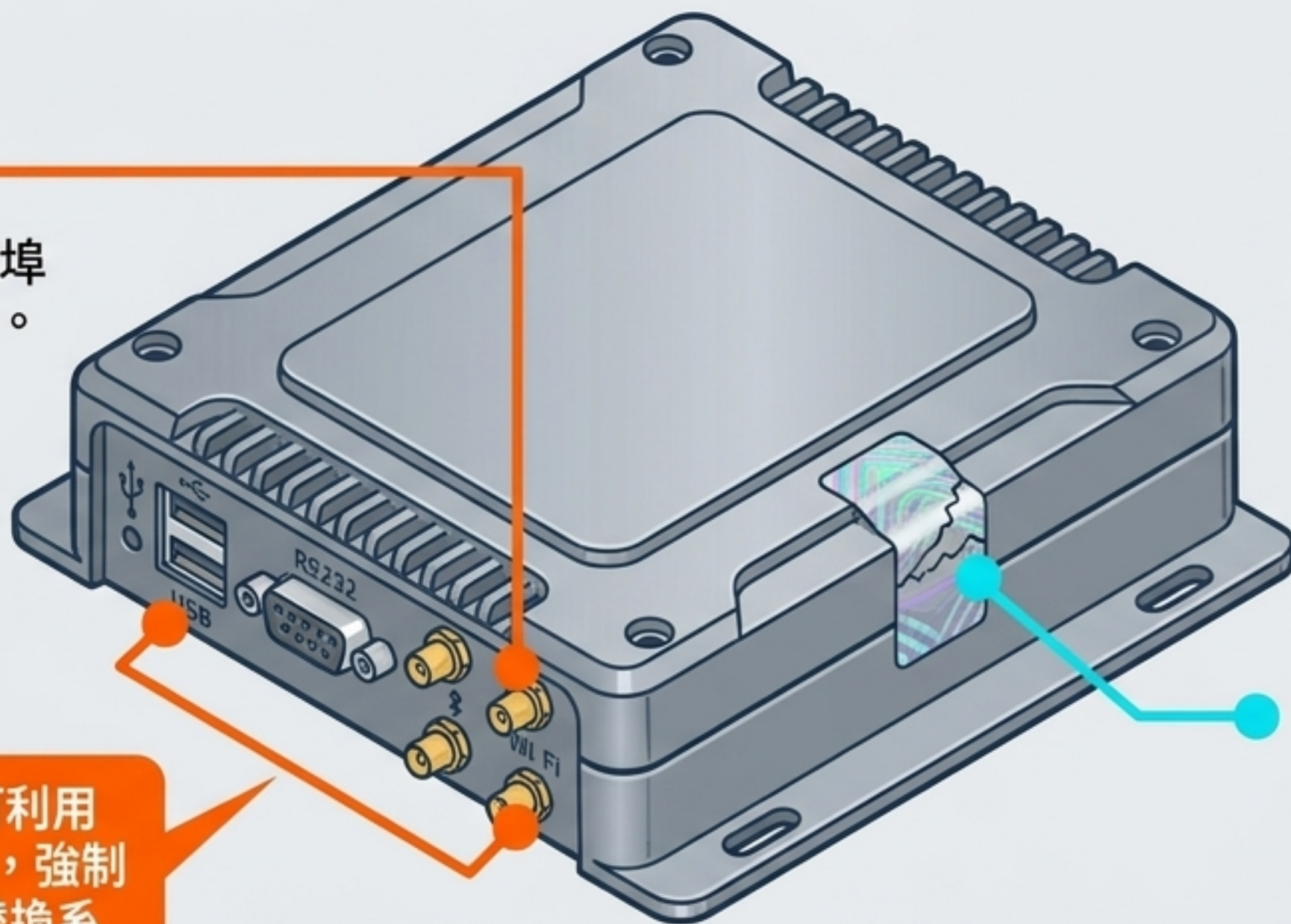
閘進器 (Gateway)

感測層 (Sensing Layer)

邊緣裝置 (Edge Devices)

高風險連接埠

應開啟最少數量的對外連接埠
(USB, RS232, 藍牙, Wi-Fi)。



實體防篡改保護

為防止裝置產品本身遭物理竄改，需增加硬體保護成本。
防護手段：貼附防拆封條 (Tamper-evident seals)、鉛封保護。



USB 致命傷：駭客可利用含作業系統的隨身碟，強制設備從 USB 啟動，替換系統並竊取檔案。

IoT 安全防禦查核清單

設備與硬體

- ☐ 關閉非必要的實體連接埠 (如 USB, RS232)。
- ☐ 啟用設備內建的硬體安全機制與防拆封條。

網路與傳輸

- ☐ 確保系統與設備間的通訊落實 SSL/TLS 加密。
- ☐ 限制雲端與網頁介面，防範 XSS 與 SQLi 攻擊。

系統與設定

- ☐ 強制更改預設密碼，禁用弱密碼並導入 2FA/OTP。
- ☐ 定期執行經過 Code Signing 驗證的軟韌體更新。
- ☐ 持續追蹤漏洞並套用廠商的安全修補方案。

The background features a light blue isometric grid. Various IoT devices are scattered across the grid, including a smartphone, a tablet, a laptop, a server rack, a cloud storage icon, a database cylinder, a camera, a speaker, and a monitor. These devices are interconnected by a network of dashed lines, representing a connected ecosystem.

“安全的萬物聯網， 建立在每一層架構的零信任基礎上。”

安全不是單一產品，而是從實體感測到雲端服務的持續性實踐。